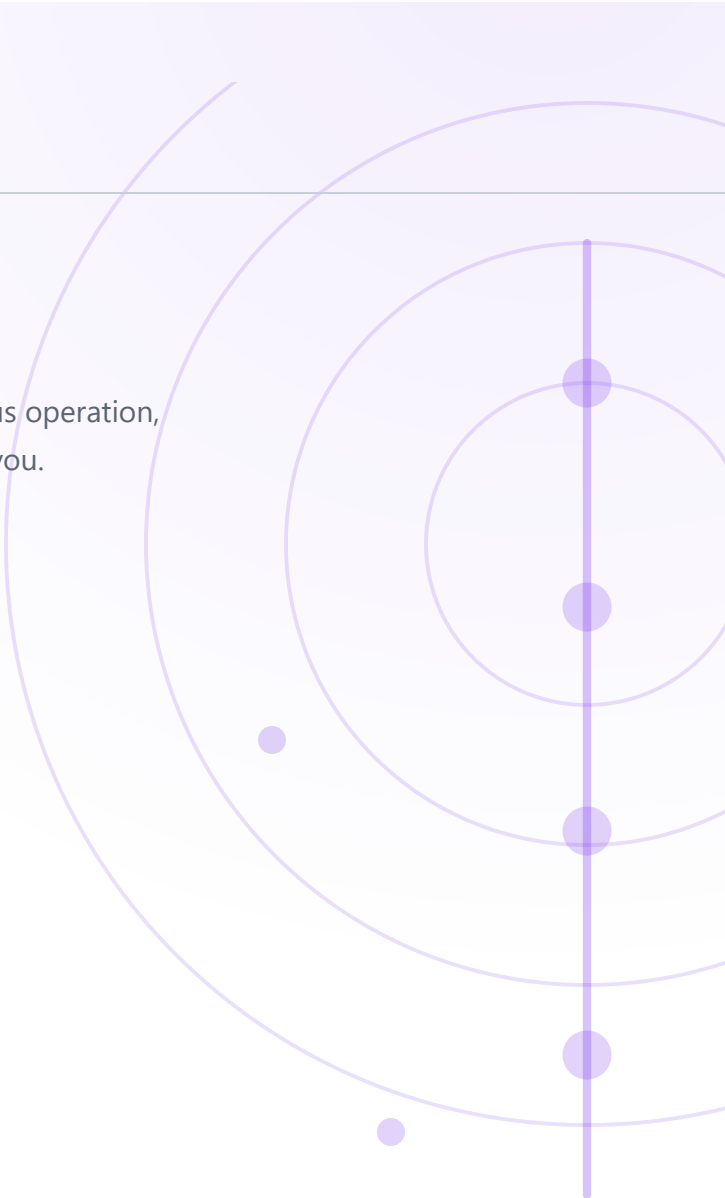


TLP: CLEAR

THREAT ACTOR ANALYSIS G0007

APT28.

A military intelligence unit with twenty years of continuous operation, which no longer needs to reach your perimeter to reach you.



ASSESSED SEVERITY

High

SUBJECT TYPE Threat actor · state	ATTRIBUTION Russia · GRU Unit 26165	FIRST OBSERVED 2004
REPORT DATE 21 August 2026	IS ACTIVE? Yes	ALSO TRACKED AS Fancy Bear · Forest Blizzard · Sednit

EXECUTIVE SUMMARY

APT28 is the cyber arm of Russian military intelligence unit 26165, running continuously since at least 2004 and tracked under eight different vendor names. It selects targets by intelligence value rather than by industry, which since 2022 has meant the logistics and technology firms moving aid into Ukraine as much as the ministries and parliaments it has always hit. Almost nothing in its current tradecraft is malware: the way in is credentials, mail and network edge devices, and the thing it takes is your mailbox.

Your exposure follows what you do, not what sector you are in. A freight forwarder became a priority target because of what it moves. Any organisation that picks up a policy, defence or aid-delivery role acquires this actor's attention with it, and the sector table in Part 1 will be the wrong guide the week that changes.

The access outlives the password reset. Mailbox delegate permissions, Sieve forwarding rules and application passwords created to bypass 2FA all persist after credentials are rotated. An incident response that stops at "we reset the account" leaves this actor reading the mail.

They no longer need to reach your perimeter. Since 2024 the group has been hijacking DNS on consumer routers, then sitting in the middle of connections to login pages. That equipment belongs to your staff, not to you, and no corporate control touches it — which makes phishing-resistant MFA the control that still works when the network underneath is lying.

One zero-day, held for a year, used for another eight months after the fix. The Outlook flaw needed no user interaction at all and was still productive long after patching because estates had not applied it. Time-to-patch is the variable this actor has repeatedly exploited, not novelty.

Eight names, one unit. Fancy Bear, Forest Blizzard, Sednit, Sofacy, STRONTIUM, Pawn Storm, IRON TWILIGHT and Fighting Ursa are the same organisation. Feeds that treat them separately will show several small problems where there is one persistent one.

Written analysis

Who the subject is, what it has done in order, and which sectors sit in its path. Part 2 is how a compromise actually unfolds.

Twenty years, one unit, eight names

APT28 is the cyber arm of a military intelligence unit rather than a criminal enterprise, and almost everything about its behaviour follows from that. The UK NCSC assesses it is almost certainly the Russian General Staff Main Intelligence Directorate's 85th Main Special Service Centre, **military unit 26165**; the United States and United Kingdom governments have both linked the group publicly to that unit. ⁶ ² MITRE tracks it as G0007 and records activity since at least 2004, which makes it one of the longest-running tracked intrusion sets in the catalogue. ¹ The name sprawl is unusual even by threat-intelligence standards — Fancy Bear, Forest Blizzard, Sednit, Sofacy, STRONTIUM, Pawn Storm, IRON TWILIGHT and Fighting Ursa all refer to the same unit, so reporting that looks like four separate campaigns is frequently one. ¹

The tradecraft is **broad rather than deep in any single technique**, which is what separates this group from a ransomware crew with one reliable way in. Initial access comes from credential guessing and password spraying, spearphishing, abuse of Microsoft Exchange mailbox permissions, cross-site scripting against webmail, and — when it suits — a zero-day. ⁴ Post-compromise, the group runs custom tooling with a long lineage: Zebrocy downloaders and backdoors, X-Agent, Drovorub, and the GooseEgg launcher. ¹ It has also shown a persistent appetite for network edge devices, compromising Ubiquiti kit to collect authentication material and, more recently, SOHO routers to manipulate DNS. ³

Two things about targeting are worth holding onto. First, the aperture is **intelligence value, not sector prestige**: the group has hit a national parliament, a chemical-weapons watchdog, election committees, ministries of defence and foreign affairs, and — since 2022 — the logistics and technology companies moving aid into Ukraine. Second, **it does not need to reach you directly**. The 2026 DNS hijacking operations compromise consumer routers opportunistically and then filter downstream for users of interest, which means an organisation can be touched through an employee's home network rather than its own perimeter. ⁶

Activity, oldest first

2015

German parliament compromised

The NCSC attributes cyber attacks against the German Bundestag to the group, including data theft and the disruption of email accounts belonging to German Members of Parliament and the Vice Chancellor. The operation establishes the pattern that recurs for the next decade: mailbox access at a legislature, taken for collection rather than disruption. ⁶

2016

US election committees and campaign staff targeted

MITRE records the compromise of the Democratic National Committee, the Democratic Congressional Campaign Committee and the Hillary Clinton presidential campaign. The activity combines credential theft against email accounts with the subsequent staged release of stolen material, pairing collection with influence rather than treating them as separate operations. ¹

2018-04

Attempted intrusion at the OPCW

The NCSC attributes an attempted attack against the Organisation for the Prohibition of Chemical Weapons in April 2018, intended to disrupt independent analysis of chemicals weaponised by the GRU in the United Kingdom. The target is an international body rather than a state, and the objective is interference with an investigation into the sponsor's own activity. ⁶

2020-06

GooseEgg in use for privilege escalation

Microsoft assesses the custom **GooseEgg** launcher has been in use since at least June 2020 and possibly as early as April 2019. It exploits CVE-2022-38028 in the Windows Print Spooler by modifying a JavaScript constraints file and executing it with SYSTEM permissions, then runs batch scripts such as `execute.bat` and `doit.bat` to install a scheduled task for persistence and extract registry hives containing credentials. ²

2022

Targeting expands to the aid supply chain

As Russian forces fail to meet their objectives in Ukraine and Western states supply aid, unit 26165 broadens its targeting to Western logistics entities and technology companies involved in coordinating, transporting and delivering that assistance. Defence, IT services, maritime, airports, ports and air traffic management organisations across NATO members are all drawn in, alongside internet-connected cameras at Ukrainian border crossings and near military installations. ⁴ ⁵

2022-03

Outlook flaw exploited as a zero-day for twenty months

Unit 42 records exploitation of CVE-2023-23397 beginning 18 March 2022, a year before public disclosure. A crafted email causes Outlook to send an NTLM authentication message to an attacker-controlled server *with no user interaction*; the group captures the NTLMv2 hash and relays it to impersonate the victim. Exploitation continues in two further waves after the patch, reaching at least **30 organisations across 14 nations over twenty months**. Compromised Ubiquiti devices collect the NTLM messages, and the mail is sent from co-opted public mail services. [3](#)

2023-09

Operation RoundPress turns webmail against its users

ESET, with *medium confidence*, attributes a campaign against high-value webmail servers to the group, running from at least September 2023 into December 2024. Spearphishing mail carries cross-site scripting payloads that inject JavaScript into the victim's webmail page, initially against Roundcube and later Horde, MDAemon and Zimbra. The SpyPress payloads steal webmail credentials and exfiltrate mail and contacts; the MDAemon variant additionally takes two-factor secrets and creates application passwords to bypass 2FA, while the Roundcube variant installs Sieve rules that forward incoming mail to attacker addresses. [7](#)

2024

Routers repurposed into a DNS hijacking network

From 2024 into 2026 the group configures virtual private servers as malicious DNS resolvers and points compromised routers at them. TP-Link WR841N devices are exploited, likely through CVE-2023-50224, using a crafted HTTP GET request to retrieve credentials and a second to rewrite the router's DHCP DNS settings — typically setting the primary resolver to attacker infrastructure while leaving the original as secondary. Downstream laptops and phones inherit the setting, lookups for email and login domains resolve to actor-controlled addresses, and adversary-in-the-middle attacks harvest passwords and OAuth tokens. MikroTik routers in Ukraine are handled interactively rather than opportunistically. [6](#)

2025-05

Ten-nation advisory on the logistics campaign

The NCSC publishes a joint advisory on 21 May 2025 with the United States, Germany, the Czech Republic, Poland, Australia, Canada, Denmark, Estonia, France and the Netherlands, setting out the campaign against Western logistics and technology organisations. Initial access is attributed to credential guessing, spearphishing and exploitation of Microsoft Exchange mailbox permissions, and the recommended mitigation leads with phishing-resistant multi-factor authentication. [4](#) [5](#)



Router operations detailed publicly

The NCSC publishes a technical advisory on 7 April 2026 describing the DNS hijacking infrastructure, including two clusters of virtual private servers identifiable by SSH banners on non-standard ports alongside `dnsmasq` on UDP 53, and a list of TP-Link models observed being targeted. The advisory assesses the operations as opportunistic, with the actor gaining visibility of a large pool of candidate users and filtering at each stage for those of intelligence value. ⁶

Patience, breadth, and somebody else's router

Most write-ups of this group reach for the 2016 election material, which is the least useful part of the record for a defender. What the last four years show is an intelligence unit that widened its aperture rather than sharpening one technique: from parliaments and treaty bodies to the freight forwarders and air traffic managers moving aid, and from spearphishing into whatever the target's mail estate happens to run. The Outlook flaw is the exception that proves the pattern — a genuine zero-day, held for a year, then used for another eight months after the patch because enough estates had not applied it. Everything else in the record is credentials, mailboxes and edge devices, which are cheaper to maintain and far harder to eradicate.

- 1 Your mail estate is the target, not the route to it.** Mailbox permissions, webmail XSS, Sieve forwarding rules, stolen 2FA secrets and application passwords all appear in the record. Several of these survive a password reset, so incident response that stops at credentials leaves the access intact.
- 2 Eight names, one unit.** Fancy Bear, Forest Blizzard, Sednit, Sofacy, STRONTIUM, Pawn Storm, IRON TWILIGHT and Fighting Ursa are the same actor. Threat feeds that treat them separately will show four small problems where there is one persistent one.
- 3 Selection is by role, not by industry.** A logistics firm became a priority target because of what it moves, not what it is. Any organisation that acquires a policy, defence or aid-delivery function acquires this actor's attention with it, and the sector table below will be the wrong guide the day that changes.
- 4 The perimeter is not the boundary.** Hijacked home routers put an adversary-in-the-middle between staff and their login pages, on equipment no corporate control touches. Phishing-resistant MFA is what survives that; an OTP does not.
- 5 Assume the dwell time is long.** This unit has run continuously for two decades and held a zero-day for a year before using it at scale. Detection tuned to a smash-and-grab tempo is tuned for the wrong opponent.

Selected on what you do, not what you are

The levels below track where victims have actually been reported, and this group's victimology follows function rather than sector: what matters is whether an organisation touches policy, defence, or the movement of aid.

Government and public administration		CRITICAL	The most consistently documented target across two decades — a national parliament in 2015, election committees in 2016, and ministries of defence, foreign affairs and internal affairs named in the exploitation of the Outlook flaw.
Defence and defence industry		CRITICAL	Defence ministries appear in Unit 42's victimology for the Outlook campaign, and Eastern European defence companies are named among the webmail targets in 2024.
Logistics, transport and aviation		CRITICAL	The explicit subject of a ten-nation advisory: maritime operators, airports, ports and air traffic management, selected for their role in moving aid to Ukraine rather than for anything about the sector itself.
Technology and IT services		HIGH	Named alongside logistics in the same advisory, and attractive as a route into the organisations these firms serve rather than as an end in itself.
Energy and utilities		HIGH	Energy production and distribution is listed among the priority sectors in Unit 42's account of the Outlook exploitation, though it appears less often than government and defence.
International organisations and NGOs		HIGH	The OPCW intrusion attempt is the clearest case, and Microsoft names non-governmental organisations among those hit with GooseEgg. Bodies investigating or constraining Russian state activity are a recurring target.

Education and research		MODERATE	Microsoft lists the education sector among GooseEgg victims, but it appears once rather than repeatedly, and no specific institution is named in the cited reporting.
Retail and hospitality		LOW	Absent from every source reviewed. The level reflects that absence rather than any protection — a retail firm handling aid logistics would sit in the critical row above on the strength of that role alone.
Organisations with no policy, defence or aid-delivery role		MINIMAL	This group selects on intelligence value, so an organisation outside those themes is unlikely to be a deliberate target. The 2026 router operations are the caveat: opportunistic DNS hijacking can still sweep up an employee's home network before filtering discards it.

 Critical — actively targeted
  High — fits the victim profile
  Moderate — plausible, not observed

 Low — outside the pattern
  Minimal — no indication

Ask what your organisation touches, not which row it sits in. Every critical row above is there because of a function — making policy, supplying defence, moving aid — rather than an industry code. A firm that picks up one of those functions moves up this table the week it does so, and nothing about its sector will have changed.

For *how* a compromise actually unfolds — the techniques, the tooling and the order they run in — see the companion attack-flow report.

What this analysis is built on

- 1 MITRE ATT&CK — Groups: APT28 (G0007) — <https://attack.mitre.org/groups/G0007/>
- 2 Microsoft Threat Intelligence — Analyzing Forest Blizzard's custom post-compromise tool for exploiting CVE-2022-38028 — <https://www.microsoft.com/en-us/security/blog/2024/04/22/analyzing-forest-blizzards-custom-post-compromise-tool-for-exploiting-cve-2022-38028-to-obtain-credentials/>
- 3 Palo Alto Unit 42 — Fighting Ursa aka APT28: illuminating a covert campaign (CVE-2023-23397) — <https://unit42.paloaltonetworks.com/russian-apt-fighting-ursa-exploits-cve-2023-23397/>
- 4 NCSC UK and partners — UK and allies expose Russian intelligence campaign targeting western logistics and technology organisations, 21 May 2025 — <https://www.ncsc.gov.uk/news/uk-partners-expose-russian-intelligence-campaign>
- 5 CISA — AA25-141A, Russian GRU targeting Western logistics entities and technology companies — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-141a>
- 6 NCSC UK — APT28 exploit routers to enable DNS hijacking operations, 7 April 2026 — https://www.ncsc.gov.uk/sites/default/files/2026-04/NCSC_APT28-exploit-routers-to-enable-DNS-hijacking-operations.pdf
- 7 ESET Research — Operation RoundPress: targeting high-value webmail servers — <https://www.welivesecurity.com/en/eset-research/operation-roundpress/>

Confidence and sourcing. The attribution to GRU unit 26165 is a published government assessment, carried by the UK NCSC at "almost certainly" and stated jointly by the US and UK governments; it is reported here at that strength and not upgraded. The Operation RoundPress activity is attributed by ESET at *medium* confidence and is described as such in the text. The alias list is MITRE's. One sourcing limitation is worth stating plainly: the CISA advisory page blocks automated retrieval, so the logistics campaign detail rests on the NCSC publication of the same joint advisory, with the CISA record cited alongside it rather than read directly. Sector risk levels are analyst assessments, not measured values; they deliberately share a colour ramp with CVSS severity but are rendered as meters rather than scores so the two are not confused.

ATT&CK attack flow

How a compromise unfolds, tactic by tactic and in order. Part 1 established who is at risk and why; this part is how they get hit.

ATTACK FLOW **G0007**

APT28.

An intrusion that increasingly starts on equipment you do not own. The first two phases below happen on rented servers and other people's routers, before anything touches the target — and the last phase takes mail rather than money.

ALSO TRACKED AS

Fancy Bear

Forest Blizzard

Sednit

Sofacy

STRONTIUM

Pawn Storm

Fighting Ursa

ATTRIBUTION Russia · GRU Unit 26165	ACTIVE SINCE 2004	OBJECTIVE Espionage
REACHES YOU VIA Mail · credentials	COLLECTION TARGETS Government · defence · logistics	MAPPING Derived

Two phases before they touch you, and none of it is malware

Ordered as the operation runs rather than as the matrix lists — escalation is shown before persistence because the launcher has to reach SYSTEM before the scheduled task it installs is worth anything. Eight tactics carry no techniques and are named in the footer rather than filled in.

01



RESOURCE DEVELOPMENT

Build a DNS service out of rented servers and other people's routers

T1583.003

Acquire Infrastructure: Virtual Private Server — configures rented servers as malicious DNS resolvers. Two clusters are identifiable by their banners: SSH on TCP `56777` or `35681`, with `dnsmasq 2.85` answering on UDP 53.

T1584.008

Compromise Infrastructure: Network Devices — takes over SOHO routers, principally TP-Link models including the `WR841N`, `Archer C5` and `C7`, and rewrites their DHCP-supplied DNS settings to point at those resolvers. MikroTik devices in Ukraine are handled by hand rather than at scale.

↓ Infrastructure that answers DNS is only useful once something is pointed at it, or once a message lands in a mailbox.

02



INITIAL ACCESS

Two doors: the router's web page, and the inbox

T1190

Exploit Public-Facing Application — against the router's own web interface, likely through CVE-2023-50224 on the WR841N. One crafted HTTP GET retrieves stored credentials, a second rewrites the DNS settings. The original resolver is demoted to secondary rather than removed, so name resolution keeps working and nothing appears broken.

T1566

Phishing — carries two different operations: cross-site scripting payloads that run inside the victim's webmail session, and crafted messages that make Outlook authenticate outbound. Sent from co-opted public mail services rather than actor-registered domains, so sender reputation gives nothing away.

↓ A foothold on a Windows host is worth nothing at user privilege, so the first thing to run is the thing that climbs.

03



EXECUTION

Let a batch file do the work the implant would be caught doing

T1059.003

Command and Scripting Interpreter: Windows Command Shell — `GooseEgg` spawns elevated processes and drives them from batch scripts named `execute.bat` and `doit.bat`. The launcher itself does very little, which is what keeps it small and unremarkable.

↓ Those scripts need `SYSTEM` before they can touch a registry hive or install a task that survives.

04



PRIVILEGE ESCALATION

A print spooler bug, held quietly for four years

T1068

Exploitation for Privilege Escalation — `GooseEgg` exploits CVE-2022-38028 in the Windows Print Spooler by modifying a JavaScript constraints file and executing it with `SYSTEM` permissions. In use since at least June 2020 and possibly April 2019, which is years before the flaw was publicly fixed.

↓ With `SYSTEM` in hand, the next move is to make sure the access outlives both the reboot and the password reset.

05



PERSISTENCE

One task on the host, one permission on the mailbox

T1053.005

Scheduled Task/Job: Scheduled Task — installed through the same batch scripts, so the launcher returns after reboot rather than depending on the original foothold staying open.

T1098.002

Account Manipulation: Additional Email Delegate Permissions — alters Exchange mailbox permissions so mailboxes of interest can be read without authenticating as their owner. Named in the ten-nation advisory as both a way in and a way to stay.

↓ Access to one estate is a foothold; access to its credentials is a key to the next one.



Five ways to take an identity, and only one involves malware

- T1110.003** Brute Force: Password Spraying — guessed credentials across many accounts, named as a primary route into logistics and technology organisations. The joint advisory leads its mitigations with phishing-resistant multi-factor authentication for exactly this reason.
- T1187** Forced Authentication — CVE-2023-23397 makes Outlook authenticate to an attacker-controlled server with *no user interaction*. The NTLMv2 hash is captured and relayed. Used as a zero-day from 18 March 2022 and in two further waves after the patch, against at least 30 organisations in 14 nations. **Compromised Ubiquiti devices** collect the messages.
- T1557** Adversary-in-the-Middle — once a hijacked router resolves a login domain to actor infrastructure, the operator sits in the connection and harvests passwords and OAuth tokens from browsers and desktop clients alike. Lookups outside the targeting criteria resolve normally, so nothing about the network feels wrong.
- T1111** Multi-Factor Authentication Interception — **SpyPress.MDAEMON** steals two-factor secrets from the webmail session and creates application passwords, which are honoured without a second factor and therefore outlive the victim's MFA entirely.
- T1003.002** OS Credential Dumping: Security Account Manager — registry hives extracted after **GooseEgg** reaches SYSTEM, by the same scripts that installed the scheduled task.

↓ Everything above exists to reach one thing, and it is not the network.



Take the mail, then arrange to keep receiving it

- T1114** Email Collection — credentials stolen and mail and contacts exfiltrated through JavaScript injected into the victim's own webmail page. Against Roundcube first, later Horde, MDAemon and Zimbra, targeting Ukrainian government bodies and Eastern European defence companies. **SpyPress.ROUNDcube** , **SpyPress.MDAEMON** .
- T1114.003** Email Collection: Email Forwarding Rule — Sieve rules installed in the mailbox forward incoming mail onward automatically. This is the part that survives a password reset, because the rule belongs to the mailbox and not to the session that created it.

A twenty-year toolset, and the newest parts are the smallest

The old names — X-Agent, Zebrocy, Drovorub — are full implants from an era when the objective was a host. The recent additions are a privilege-escalation launcher and two lumps of JavaScript that live in a webmail page, because the objective is now the mailbox and there is no reason to put a binary on disk to reach it.

GooseEgg

Launcher that exploits the Print Spooler to run payloads as SYSTEM

CRED ACCESS

SpyPress.ROUND CUBE

Webmail implant: steals credentials, exfiltrates mail, plants forwarding rules

BACKDOOR

SpyPress.MDAEMON

Webmail implant that also takes 2FA secrets and creates application passwords

CRED ACCESS

Zebrocy

Long-running downloader and backdoor family in Delphi and Autolt

BACKDOOR

Drovorub

Linux implant associated with the group

BACKDOOR

X-Agent

Core modular backdoor of the older toolset

BACKDOOR

Mimikatz

Credential theft on Windows hosts

CRED ACCESS

What this mapping is built on

- 1 MITRE ATT&CK — Groups: APT28 (G0007) — <https://attack.mitre.org/groups/G0007/>
- 2 Microsoft Threat Intelligence — Analyzing Forest Blizzard's custom post-compromise tool for exploiting CVE-2022-38028 — <https://www.microsoft.com/en-us/security/blog/2024/04/22/analyzing-forest-blizzards-custom-post-compromise-tool-for-exploiting-cve-2022-38028-to-obtain-credentials/>
- 3 Palo Alto Unit 42 — Fighting Ursa aka APT28: illuminating a covert campaign — <https://unit42.paloaltonetworks.com/russian-apt-fighting-ursa-exploits-cve-2023-233397/>
- 4 NCSC UK and partners — UK and allies expose Russian intelligence campaign targeting western logistics and technology organisations — <https://www.ncsc.gov.uk/news/uk-partners-expose-russian-intelligence-campaign>
- 5 NCSC UK — APT28 exploit routers to enable DNS hijacking operations, 7 April 2026 — https://www.ncsc.gov.uk/sites/default/files/2026-04/NCSC_APT28-exploit-routers-to-enable-DNS-hijacking-operations.pdf
- 6 ESET Research — Operation RoundPress: targeting high-value webmail servers — <https://www.welivesecurity.com/en/eset-research/operation-roundpress/>

Read the ordering correctly. The phases run in the order the operation runs, not the order the matrix lists. Privilege Escalation appears before Persistence because the launcher must hold SYSTEM before the scheduled task it installs is worth anything, and the registry hives it reads are unreadable without it.

Derived mapping — read before citing. MITRE publishes a G0007 entry, but the techniques on this page were **derived by analysis** from the cited reporting rather than copied from it, so they will not match that entry row for row. Every technique ID and tactic assignment was verified against attack.mitre.org before use; applying each one to this actor remains an analytical judgment. Two placements are worth flagging: the Outlook flaw is mapped to Credential Access rather than Initial Access because what it yields is an NTLM hash, and the router work sits in Resource Development because those devices are infrastructure for the operation rather than the target of it.

Coverage gaps. Eight Enterprise tactics carry no techniques here — Reconnaissance, Stealth, Defense Impairment, Discovery, Lateral Movement, Command and Control, Exfiltration and Impact. That reflects what the cited sources describe, not the limit of this actor's capability: a group operating for twenty years plainly moves laterally and exfiltrates, but the reporting reviewed here does not describe how, and inventing the steps would produce a more complete-looking page that asserts things nobody has observed.

Attribution. The link to GRU unit 26165 is a published government assessment, carried by the UK NCSC at "almost certainly" and stated jointly by the US and UK governments. The webmail activity is attributed by ESET at *medium* confidence, and is the one part of this page resting on a single vendor.

DEFENSIVE PRIORITIES

Ordered by the tactics this actor was actually observed using, not by general good practice. Each item names what it denies.

- 1. Enforce phishing-resistant MFA on every externally reachable account, starting with mail.**
Denies password spraying (T1110.003), which is a named primary route into logistics and technology targets, and blunts the credential harvesting the router adversary-in-the-middle work depends on (T1557). An OTP does not survive a machine in the middle; a passkey does.
- 2. Audit Exchange mailbox delegate permissions and every mailbox forwarding or Sieve rule, and alert on new ones.**
Denies the two techniques that outlive a password reset: additional email delegate permissions (T1098.002) and email forwarding rules (T1114.003). If you do only one thing after suspecting this actor, do this one.
- 3. Revoke application passwords and re-enrol MFA for any account whose webmail session may have been compromised.**
Denies multi-factor authentication interception (T1111). The MDAEMON payload creates application passwords precisely because they are honoured without a second factor, so rotating the user's password alone leaves that access intact.
- 4. Block outbound SMB and NTLM authentication to the internet at the egress point, and confirm Outlook is patched.**
Denies forced authentication (T1187). The exploit works by making the client authenticate outbound with no user interaction, so the egress control holds even against a variant the patch does not cover.
- 5. Confirm the Print Spooler fix is deployed, and disable the service where it is not needed.**
Denies exploitation for privilege escalation (T1068) through the flaw the GooseEgg launcher exists to abuse. The launcher does nothing without it.
- 6. Treat staff home routers as hostile infrastructure: require the corporate VPN or a DNS resolver you control, and give guidance on replacing end-of-life consumer devices.**
Denies the value of compromised network devices (T1584.008) and the DNS redirection built on them. You cannot patch equipment you do not own, so the answer is to stop trusting what it tells you about name resolution.

7. Alert on scheduled tasks created by SYSTEM-level processes and on registry hive access outside backup windows.

Denies the persistence and credential-theft pair that follows escalation (T1053.005, T1003.002). Both are carried out by batch scripts rather than by the implant, so detection built on malware signatures will not see them.